LAPORAN TEKNIS - CODE QUALITY REVIEW

Audit Bug Proyek HRM

Hasil audit menyeluruh atas aplikasi HRM berbasis Laravel dan Livewire 3: 37 temuan terverifikasi pada lapisan backend, otorisasi, dan frontend, lengkap dengan lokasi kode, analisis dampak, dan rekomendasi perbaikan bertahap.

Dokumen Internal Tim Engineering - 31 Oktober 2026

Daftar Isi

1. Ringkasan Eksekutif **2**

1.1 Lingkup dan Metode Audit 2

2. Tabel Ringkasan Master Temuan **2**

3. Rincian Temuan Kritis **5**

H1 - Race condition pembuatan periode payroll ganda 5

H2 - Bukti pembayaran payroll dan lembur disimpan di disk publik (akses tanpa autentikasi) 5

H3 - Penghapusan permanen data payroll berjalan setiap halaman dibuka, tanpa cek otorisasi 5

4. Rincian Temuan Sedang **6**

5. Rincian Temuan Rendah dan Info **8**

6. Area yang Terverifikasi Bersih **11**

7. Rekomendasi Urutan Perbaikan **11**

1. Ringkasan Eksekutif

Laporan ini menyajikan hasil audit menyeluruh atas kode Proyek HRM (Laravel + Livewire 3) yang mencakup lapisan backend (Services, Controllers, Models, Routes, Policies), komponen Livewire, dan frontend (template Blade serta JavaScript). Seluruh temuan telah diverifikasi langsung terhadap kode sumber - bukan spekulasi - lengkap dengan lokasi berkas dan baris. Tidak ada perubahan kode yang dilakukan sebelum laporan ini disetujui.

3
Temuan Kritis (segera diperbaiki)

13
Temuan Sedang (integritas data / keamanan)

21
Temuan Rendah + 1 Info (kerapian / penguatan)

Tiga temuan kritis yang paling mendesak: (1) bukti pembayaran gaji dan lembur tersimpan di disk publik sehingga dapat diunduh tanpa login; (2) penghapusan permanen data payroll berjalan setiap halaman detail payroll dibuka tanpa pemeriksaan otorisasi; dan (3) race condition yang dapat menciptakan dua periode payroll untuk bulan yang sama. Ketiganya menyangkut kerahasiaan data keuangan karyawan dan integritas data payroll, sehingga direkomendasikan untuk dieksekusi lebih dahulu.

1.1 Lingkup dan Metode Audit

Area	Yang Diperiksa
Backend	app/Services (14 layanan), app/Http/Controllers, app/Models, app/Enums, app/Support/IdObfuscator, routes/web.php, migrasi database, konfigurasi bootstrap
Otorisasi	app/Livewire (seluruh komponen dan form), app/Policies, keterkaitan gate/policy dengan route dan aksi Livewire
Frontend	resources/views (seluruh template aplikasi, termasuk print views), cross-check setiap wire:click, $wire, dan Livewire.dispatch terhadap method komponen, resources/js, vite.config.js

Tabel 1. Lingkup audit per lapisan aplikasi.

2. Tabel Ringkasan Master Temuan

Tabel berikut merangkum seluruh 37 temuan terverifikasi. Kode ID digunakan sebagai acuan pada rincian di Bab 3-5. Beberapa temuan dari pemeriksaan yang berbeda tumpang tindih dan telah digabungkan (mis. cleanupTrashedEmployees dilaporkan pada dua pemeriksaan).

ID	Severitas	Area	Lokasi (berkas:baris)	Ringkasan Temuan
H1	Kritis	Backend	app/Services/PayrollService.php:783-790 (juga app/Livewire/Payrolls/Index.php:169-177)	Race condition pembuatan periode payroll ganda
H2	Kritis	Livewire	app/Livewire/Payrolls/Show.php:836; app/Livewire/Overtimes/PeriodAttendance.php:471	Bukti pembayaran payroll dan lembur disimpan di disk publik (akses tanpa autentikasi)

ID	Severitas	Area	Lokasi (berkas:baris)	Ringkasan Temuan
H3	Kritis	Livewire	app/Livewire/Payrolls/Show.php:105-150	Penghapusan permanen data payroll berjalan setiap halaman dibuka, tanpa cek otorisasi
H4	Sedang	Backend	app/Support/IdObfuscator.php:75-81	Obfuskasi ID dapat dilewati - ID numerik mentah tetap diterima
H5	Sedang	Livewire	app/Livewire/Forms/SalaryComponentForm.php:402-435, 517, 540	Properti type komponen gaji ditulis ke database tanpa validasi
H6	Sedang	Livewire	app/Livewire/Forms/EmployeeForm.php:150, 399; app/Livewire/Employees/Index.php:236	Kebijakan password lemah: default "1" dan panjang minimal 1 karakter
H7	Sedang	Backend	app/Services/AttendanceService.php:222-238	Import absensi gagal atau salah tanggal pada hari 29-31
H8	Sedang	Backend	app/Services/PayrollService.php:2757, 2901	Potongan payslip vs kredit kasbon tidak sinkron (kebocoran uang)
H9	Sedang	Backend	app/Services/CashAdvanceService.php:2534-2555	syncOpenPayrollLinesForInstallment dapat menggandakan saldo ke beberapa line
H10	Sedang	Backend	app/Services/PayrollService.php:795-806	createPeriod menerima tanggal kustom tanpa validasi urutan dan bulan
H11	Sedang	Backend	app/Services/OvertimeService.php:219-237	Pemeriksaan overlap lembur melewatkan pengajuan lintas hari berikutnya
H12	Sedang	Backend	app/Services/CashAdvanceService.php:965 (vs 1081)	Epsilon status PAID installment tidak konsisten
H13	Sedang	Livewire	app/Livewire/Overtimes/PeriodAttendance.php:326-351; OvertimeService.php:786-820	Field payout lembur mingguan disimpan tanpa validasi dari input client
H14	Sedang	Livewire	app/Livewire/Payrolls/Show.php:329-337, 736-740, 781-785, 894-922	Payroll item dimuat tanpa scope periode; gate dicek terhadap model yang salah
H15	Sedang	Livewire	app/Livewire/CashAdvances/Index.php (store:384, showDetail:509, openApproval:533, approve:574, reject:624, approveDirect:652, rejectDirect:691, openPayment:731, openPaymentForInstallment:774, approvePayment:842, rejectPayment:885)	AuthorizationException tertelan menjadi toast "data tidak ditemukan"
H16	Sedang	Blade	resources/views/livewire/payrolls/show.blade.php:994; manage-item.blade.php:547, 1709	Output mentah ({!! !!}) untuk teks catatan dari database (potensi XSS)
R1	Rendah	Backend	app/Services/PayrollService.php:3003-3011	updateItemPayment menghapus detail bank/catatan dengan null
R2	Rendah	Backend	app/Services/OvertimeService.php:984-989	Ringkasan lembur bulanan salah batas periode mingguan
R3	Rendah	Backend	app/Services/PayrollService.php:970-997	DAYOFWEEK() MySQL-only dan N+1 pada perhitungan prorata

ID	Severitas	Area	Lokasi (berkas:baris)	Ringkasan Temuan
R4	Rendah	Backend	app/Services/EmployeeService.php:522-533	deleteSalaryHistory dapat mengangkat gaji masa depan menjadi gaji saat ini
R5	Rendah	Backend	app/Services/PayrollService.php:2966-2978	markItemAsPaid menaikkan status periode tanpa payment_method
R6	Rendah	Backend	app/Services/OvertimeService.php:845-897	State machine pembayaran periode lembur longgar
R7	Rendah	Backend	app/Http/Controllers/PayrollPrintController.php:106-113	Print slip batch N+1 (query tak terbatas per item)
R8	Rendah	Backend	app/Services/CashAdvanceService.php (895, 1940, 2127, 2420); PayrollService.php (2812, 2958)	Konstanta toleransi uang campur aduk (0.001 / 0.01 / tanpa epsilon)
R9	Rendah	Backend	app/Services/CashAdvanceService.php:911-978	recordPayment salah melabeli alokasi multi-installment
R10	Rendah	Livewire	app/Livewire/Posts/Index.php:71-202	Aksi komponen Posts tanpa pemeriksaan role ulang
R11	Rendah	Livewire	app/Livewire/Attendances/Index.php:192-199	Validasi file import hanya cek ekstensi, bukan isi
R12	Rendah	Livewire	app/Livewire/CashAdvances/Index.php:1626	Statistik dashboard karyawan menghitung payment pending/rejected sebagai lunas
R13	Rendah	Livewire	app/Livewire/Payrolls/Show.php:701-707, 810-815	Tanggal pembayaran payroll menerima tanggal masa depan
R14	Rendah	Livewire	app/Livewire/Payrolls/ManageItem.php:2741	Fallback audit ke User::first()
R15	Rendah	Livewire	app/Livewire/Overtimes/Index.php:701-728	Modal lembur legacy membuat kehadiran 6 hari untuk semua karyawan
R16	Rendah	Blade	resources/views/livewire/payrolls/show.blade.php:796	Colspan empty-state tidak sinkron dengan kolom header
R17	Rendah	Blade	resources/views/livewire/overtimes/index.blade.php:346, 349, 1026, 1029; pending-admin-modal.blade.php:89; pending-director-modal.blade.php:84, 93	Interpolasi string JS pada onclick untuk reference_number
R18	Rendah	Blade	resources/views/livewire/cash-advances/index.blade.php:1044-1098	Init Select2 pada elemen yang tidak ada (main_employee_selector)
R19	Rendah	Blade	resources/views/layouts/app.blade.php:211, 232, 239	Bridge SweetAlert global berfallback ke delete-post
R20	Rendah	Blade	resources/views/layouts/guest.blade.php:17; package.json:10	Halaman auth bergantung pada symlink public/node_modules
R21	Info	Blade	resources/js/app.js; welcome.blade.php:14	resources/js/app.js kosong - bundle Vite bukan jalur utama aplikasi

Tabel 2. Seluruh temuan audit (37 item) beserta lokasi dan tingkat keparahan.

3. Rincian Temuan Kritis

Ketiga temuan berikut direkomendasikan untuk diperbaiki lebih dahulu karena menyangkut akses tanpa otorisasi terhadap dokumen keuangan karyawan, aksi destruktif tanpa kontrol, dan integritas data payroll.

H1 - Race condition pembuatan periode payroll ganda

Lokasi	`app/Services/PayrollService.php:783-790 (juga app/Livewire/Payrolls/Index.php:169-177)`
Area	Backend

Masalah. createPeriod() memakai pola check-then-act: cek PayrollPeriod::exists() untuk kombinasi (year, month), lalu create(). Migrasi tabel payroll_periods tidak memiliki unique index pada (year, month) - hanya index biasa dan unique pada reference_number.

Dampak. Dua request bersamaan dapat lolos pengecekan dan menghasilkan dua periode untuk bulan yang sama, masing-masing memesan nomor slip gaji sendiri. Data payroll menjadi tidak konsisten.

Rekomendasi. Tambah unique index pada (year, month) lalu tangani pelanggaran constraint, atau kunci baris sentinel dengan SELECT ... FOR UPDATE.

H2 - Bukti pembayaran payroll dan lembur disimpan di disk publik (akses tanpa autentikasi)

Lokasi	`app/Livewire/Payrolls/Show.php:836; app/Livewire/Overtimes/PeriodAttendance.php:471`
Area	Livewire

Masalah. File bukti transfer/kwitansi disimpan dengan store('payroll-proofs', 'public') dan ditampilkan langsung via asset('storage/...'). Berbeda dengan alur kasbon yang benar (disk local + SecureDocumentController dengan Gate dan audit log).

Dampak. Dokumen keuangan karyawan berisi nomor rekening dapat diunduh siapa pun yang mengetahui atau menebak URL, tanpa autentikasi, otorisasi, maupun logging.

Rekomendasi. Simpan bukti ke disk local dan sajikan melalui route terotorisasi (pola SecureDocumentController::paymentProof).

H3 - Penghapusan permanen data payroll berjalan setiap halaman dibuka, tanpa cek otorisasi

Lokasi	`app/Livewire/Payrolls/Show.php:105-150`
Area	Livewire

Masalah. mount() memanggil cleanupTrashedEmployees() yang menghapus permanen payroll item beserta lines-nya setiap page load. Dilindungi hanya middleware route role:admin|direktur, tanpa Gate::authorize. Policy PayrollPeriodPolicy::update() bahkan menolak peran direktur.

Dampak. Direktur yang sekadar melihat halaman ikut menghapus data draft secara diam-diam. Aksi destruktif berjalan pada jalur baca (read path), tanpa jejak audit seperti penghapusan lainnya.

Rekomendasi. Tambahkan gate check update pada periode dan pindahkan cleanup ke aksi eksplisit yang dipicu user.

4. Rincian Temuan Sedang

Temuan tingkat sedang umumnya menyangkut integritas data payroll/kasbon atau celah validasi input. Tabel berikut menyajikan masalah, dampak, dan rekomendasi per temuan.

ID	Lokasi	Masalah	Dampak dan Rekomendasi
H4	`app/Support/IdObfuscator.php:75-81`	**Obfuskasi ID dapat dilewati - ID numerik mentah tetap diterima** Setelah decode hashid gagal, ada fallback: jika input ctype_digit maka diterima sebagai integer. Artinya ID sekuensial 1, 2, 3 tetap valid pada semua route ber-hashid.	**Dampak:** Proteksi obfuskasi ID menjadi sia-sia dan endpoint rentan enumerasi (IDOR), terutama jika otorisasi per-record ada yang terlewat. **Rekomendasi:** Hapus fallback numerik di production; batasi hanya untuk environment testing.
H5	`app/Livewire/Forms/SalaryComponentForm.php:402-435, 517, 540`	**Properti type komponen gaji ditulis ke database tanpa validasi** rules() tidak memuat aturan untuk $type, padahal store() dan update() menulis nilainya langsung ke model: $validated['type'] = $this->type. $type adalah properti publik Livewire yang dapat dimanipulasi client melalui wire snapshot.	**Dampak:** Nilai type yang dipalsukan (mis. deduction pada komponen berkategori pendapatan) tersimpan tanpa validasi dan merusak klasifikasi allowance/deduction yang menjadi dasar perhitungan payroll. **Rekomendasi:** Tambahkan rule 'type' => ['required', Rule::in(['allowance', 'deduction'])] dan turunkan nilainya di sisi server.
H6	`app/Livewire/Forms/EmployeeForm.php:150, 399; app/Livewire/Employees/Index.php:236`	**Kebijakan password lemah: default "1" dan panjang minimal 1 karakter** Rule password hanya min:1, dan saat membuat akun karyawan dipakai default $this->password ?: '1'. UI bahkan menampilkan password awal tersebut dalam toast.	**Dampak:** Seluruh akun karyawan baru berawal dengan password yang dikenal umum; jika rotasi paksa terlewat, akun pada sistem berisi PII dan data bank praktis tidak terlindungi. **Rekomendasi:** Terapkan minimal 8 karakter, rotasi paksa pada login pertama, dan jangan kembalikan password awal dalam toast.
H7	`app/Services/AttendanceService.php:222-238`	**Import absensi gagal atau salah tanggal pada hari 29-31** Nomor hari diambil dari sel mentah lalu langsung dipakai pada $dateObj->day($dayNum). Jika sheet fingerprint memuat tanggal 31 pada bulan April/Februari, Carbon melempar InvalidFormatException dan seluruh import gagal di dalam transaksi. Heuristik bulan juga salah untuk rentang lintas bulan (setiap dayNum < start->day dipaksa ke bulan akhir).	**Dampak:** Import absensi bulan pendek gagal total, atau tanggal absensi salah bulan sehingga perhitungan kehadiran dan upah mingguan keliru. **Rekomendasi:** Validasi $dayNum terhadap daysInMonth sebelum memanggil day(), dan tentukan bulan per kolom tanggal seperti pada jalur "Lap. Log Absen".
H8	`app/Services/PayrollService.php:2757, 2901`	**Potongan payslip vs kredit kasbon tidak sinkron (kebocoran uang)** Saat payslip dibayar, $totalToDeduct = min(line->amount, remaining_amount). Gaji karyawan sudah dipotong penuh sebesar line->amount (ikut total_deductions), tetapi kredit ke kasbon hanya sebesar nilai hasil clamp.	**Dampak:** Jika line stale atau diedit manual sehingga melebihi sisa hutang, karyawan terpotong lebih besar dari hutangnya tanpa peringatan maupun kompensasi. **Rekomendasi:** Verifikasi line->amount terhadap saldo installment sebelum pembayaran dan hitung ulang payslip bila menyimpang (atau lempar error).

ID	Lokasi	Masalah	Dampak dan Rekomendasi
H9	`app/Services/CashAdvanceService.php:2534-2555`	**syncOpenPayrollLinesForInstallment dapat menggandakan saldo ke beberapa line** Loop foreach ($openLines) mengupdate setiap line payroll terbuka yang mereferensi satu installment dengan nilai penuh $unpaidBalance. Satu installment bisa dirujuk dua line (dua periode draft berturut-turut, atau lewat syncItemLines).	**Dampak:** Setiap line mendapat saldo penuh sehingga total potongan gaji menjadi dua kali lipat dari hutang sebenarnya. **Rekomendasi:** Distribusikan sisa saldo antar line, atau reset hanya line yang nilainya melebihi saldo.
H10	`app/Services/PayrollService.php:795-806`	**createPeriod menerima tanggal kustom tanpa validasi urutan dan bulan** start_date dan end_date dipakai langsung tanpa memeriksa startDate <= endDate (berbeda dengan OvertimeService::createPeriod yang memeriksa), dan tanpa memastikan tanggal berada pada bulan/tahun periode.	**Dampak:** Rentang terbalik membuat loop hari kerja menghasilkan totalWorkingDays = 0 sehingga rasio prorata 0 dan gaji pokok seluruh karyawan menjadi nol. **Rekomendasi:** Validasi startDate < endDate dan pastikan rentang berada dalam bulan/tahun periode.
H11	`app/Services/OvertimeService.php:219-237`	**Pemeriksaan overlap lembur melewatkan pengajuan lintas hari berikutnya** checkSubmissionOverlap() membatasi kandidat pada whereIn('date', [$prevDate, $date]). Pengajuan 22:00-04:00 (+1) pada hari D dapat tumpang-tindih dengan pengajuan bertanggal D+1 yang mulai 01:00, namun baris D+1 tidak pernah diambil.	**Dampak:** Pengajuan lembur yang tumpang-tindih tetap diterima sehingga jam lembur dapat terhitung ganda. **Rekomendasi:** Sertakan tanggal D+1 (addDay) dalam kandidat pengecekan.
H12	`app/Services/CashAdvanceService.php:965 (vs 1081)`	**Epsilon status PAID installment tidak konsisten** recordPayment() membandingkan tanpa toleransi: $newPaidAmount >= (float) $installment->amount, sedangkan approvePayment() dan PayrollService memakai toleransi - 0.01. Cast float dari kolom decimal:2 dapat menyisakan residu pembulatan.	**Dampak:** Installment dapat terjebak berstatus PARTIALLY_PAID selamanya (sisa 0, kasbon sudah PAID) dan terus muncul pada daftar telat bayar serta statistik ringkasan. **Rekomendasi:** Gunakan epsilon yang sama (>= amount - 0.01) pada recordPayment, atau konversi perhitungan uang ke sen (integer).
H13	`app/Livewire/Overtimes/PeriodAttendance.php:326-351; OvertimeService.php:786-820`	**Field payout lembur mingguan disimpan tanpa validasi dari input client** Array publik $periodAttendances diteruskan apa adanya ke updatePeriodAttendance(): attended_days, meal_allowance_per_day, meal_allowance_type, daily_rate. Layanan menulis langsung (total_daily_wage = attended_days * daily_rate) tanpa validasi, cek enum, atau clamp ke tarif master.	**Dampak:** Nilai snapshot yang dimanipulasi (daily_rate negatif/ekstrem, type sembarang) mengubah upah mingguan dan total periode tanpa error validasi. **Rekomendasi:** Validasi dan clamp attended_days (0-6), meal_allowance_type (enum), dan daily_rate (>= 0, atau paksa tarif master karyawan).

ID	Lokasi	Masalah	Dampak dan Rekomendasi
H14	app/Livewire/Payrolls/Show.php:329-337, 736-740, 781-785, 894-922	**Payroll item dimuat tanpa scope periode; gate dicek terhadap model yang salah** openComponentModal(), openPayItemModal(), openPaymentDetailModal(), dan openPreviewSlip() memuat PayrollItem berdasarkan ID mentah tanpa where(payroll_period_id) dan sebagian tanpa gate; openPayItemModal mengecek Gate::authorize('recordPayment', $this->period) padahal item bisa milik periode lain.	**Dampak:** State komponen (selectedItem, payingItem, previewItem) dapat dimuat dari periode lain; pemeriksaan status di level komponen dapat dilewati meski lapisan layanan tetap melakukan otorisasi ulang. **Rekomendasi:** Tambahkan scope payroll_period_id pada setiap lookup dan lakukan otorisasi terhadap periode milik item.
H15	app/Livewire/CashAdvances/Index.php (store:384, showDetail:509, openApproval:533, approve:574, reject:624, approveDirect:652, rejectDirect:691, openPayment:731, openPaymentForInstallment:774, approvePayment:842, rejectPayment:885)	**AuthorizationException tertelan menjadi toast "data tidak ditemukan"** Sebelas aksi memanggil Gate::authorize() di dalam catch (Throwable) tanpa melempar ulang AuthorizationException (berbeda dengan edit/update/delete yang melempar ulang).	**Dampak:** Penolakan policy 403 tersamar menjadi toast "Gagal!"/"Data kasbon tidak ditemukan", menyulitkan deteksi salah konfigurasi permission dan menyamarkan percobaan akses tidak sah. **Rekomendasi:** Tambahkan catch (AuthorizationException $e) { throw $e; } sebelum catch Throwable pada semua aksi tersebut.
H16	resources/views/livewire/payrolls/show.blade.php:994; manage-item.blade.php:547, 1709	**Output mentah ({!! !!}) untuk teks catatan dari database (potensi XSS)** $prevNoteText, $prorateNoteText, dan $calculationDetail['summary_text'] dirender memakai sintaks raw output Blade (tanda seru ganda) yang tidak melakukan escaping HTML. Sumbernya kolom notes/text_note yang hari ini dibuat oleh sistem, tetapi tidak ada jaminan isinya bebas markup.	**Dampak:** Jika ada HTML/script masuk ke kolom notes, markup tersebut dieksekusi/dirender mentah pada layar slip gaji (stored XSS). **Rekomendasi:** Ganti dengan escaping standar {{ }}; bangun dekorasi (bullet) di sisi server dengan HtmlString dan e() untuk bagian dinamis.

Tabel 3. Rincian 13 temuan tingkat sedang.

5. Rincian Temuan Rendah dan Info

Temuan rendah bersifat penguatan (hardening), kerapian, atau potensi masalah pada kondisi khusus. Satu temuan berkategori Info bersifat dokumentatif.

ID	Sev.	Lokasi	Masalah dan Rekomendasi
R1	Rendah	app/Services/PayrollService.php:3003-3011	**updateItemPayment menghapus detail bank/catatan dengan null.** Key bank_name, bank_account_number, bank_account_name, payment_notes memakai fallback ?? null, berbeda dengan markItemAsPaid yang memakai ?? nilai lama. **Rekomendasi:** Gunakan fallback ?? $item->bank_name seperti markItemAsPaid.

ID	Sev.	Lokasi	Masalah dan Rekomendasi
R2	Rendah	`app/Services/OvertimeService.php:984-989`	**Ringkasan lembur bulanan salah batas periode mingguan.** Period attendance dicocokkan hanya berdasarkan whereBetween('start_date', [awal, akhir bulan]). Periode mingguan yang dimulai bulan sebelumnya tetapi mencakup hari bulan ini terlewat total. **Rekomendasi:** Cek overlap (start_date, end_date) terhadap rentang bulan, bukan hanya start_date.
R3	Rendah	`app/Services/PayrollService.php:970-997`	**DAYOFWEEK() MySQL-only dan N+1 pada perhitungan prorata.** whereRaw('DAYOFWEEK(date) ...') tidak ada di SQLite/Postgres (kodebase mendukung sqlite di utilitas lain). Attendance exists() dan hitungan kehadiran per karyawan berjalan di dalam loop per item. **Rekomendasi:** Gunakan ekspresi weekday portabel dan cache hasil periodHasAttendance per periode.
R4	Rendah	`app/Services/EmployeeService.php:522-533`	**deleteSalaryHistory dapat mengangkat gaji masa depan menjadi gaji saat ini.** Setelah hapus riwayat, gaji karyawan diambil dari riwayat terbaru berdasar effective_date tanpa filter effective_date <= hari ini. **Rekomendasi:** Filter effective_date <= today dengan fallback ke entri INITIAL.
R5	Rendah	`app/Services/PayrollService.php:2966-2978`	**markItemAsPaid menaikkan status periode tanpa payment_method.** Saat item terakhir dibayar individual, periode diupdate ke PAID dengan payment_date tetapi payment_method tidak pernah diisi (berbeda dengan markAsPaid). **Rekomendasi:** Set payment_method pada periode saat transisi otomatis ke PAID.
R6	Rendah	`app/Services/OvertimeService.php:845-897`	**State machine pembayaran periode lembur longgar.** markPeriodAsPaid() hanya memblokir status PAID - periode DRAFT bisa dipaksa lunas. payEmployeeWeekly() tidak memeriksa payment_status sehingga kehadiran yang sudah dibayar bisa ditandai ulang dengan detail bank baru. **Rekomendasi:** Wajibkan status non-draft dan tambahkan guard status paid.
R7	Rendah	`app/Http/Controllers/PayrollPrintController.php:106-113`	**Print slip batch N+1 (query tak terbatas per item).** printAllSlips() memanggil getEmployeeMonthlyOvertimeSummary() per item; tiap panggilan mengeksekusi 2-3 query (submissions, employee, attendance, period attendances). **Rekomendasi:** Prefetch submissions/attendance per periode secara batch.
R8	Rendah	`app/Services/CashAdvanceService.php (895, 1940, 2127, 2420); PayrollService.php (2812, 2958)`	**Konstanta toleransi uang campur aduk (0.001 / 0.01 / tanpa epsilon).** Perbandingan "sudah lunas" memakai tiga epsilon berbeda pada empat jalur kode, dengan cast (float) dari kolom decimal:2. **Rekomendasi:** Standarisasi satu helper epsilon, atau pindahkan perhitungan uang ke integer sen.
R9	Rendah	`app/Services/CashAdvanceService.php:911-978`	**recordPayment salah melabeli alokasi multi-installment.** Satu baris CashAdvancePayment dibuat dengan cash_advance_installment_id = installment target untuk nominal penuh, padahal loop alokasi dapat membagi ke installment lain. **Rekomendasi:** Simpan alokasi per installment (baris alokasi terpisah) atau labelkan sebagai pembayaran gabungan.
R10	Rendah	`app/Livewire/Posts/Index.php:71-202`	**Aksi komponen Posts tanpa pemeriksaan role ulang.** create/store/edit/update/confirmDelete/delete hanya dilindungi oleh abort di mount(), sedangkan panggilan aksi Livewire tidak menjalankan ulang middleware route. Komponen lain di kodebase selalu re-check per aksi. **Rekomendasi:** Tambahkan abort_unless(auth()->user()?->hasRole('admin'), 403) pada tiap aksi.
R11	Rendah	`app/Livewire/Attendances/Index.php:192-199`	**Validasi file import hanya cek ekstensi, bukan isi.** Rule extensions:xls,xlsx hanya memeriksa nama file; berkas apa pun yang di-rename .xlsx lolos. Pesan kustom bahkan merujuk rule mimes yang tidak dipakai. **Rekomendasi:** Gunakan mimes:xls,xlsx (deteksi MIME) selain extensions:.

ID	Sev.	Lokasi	Masalah dan Rekomendasi
R12	Rendah	`app/Livewire/CashAdvances/Index.php:1626`	**Statistik dashboard karyawan menghitung payment pending/rejected sebagai lunas.** total_paid_transactions_count menghitung seluruh baris CashAdvancePayment tanpa filter status. **Rekomendasi:** Tambahkan where('status', 'approved') pada hitungan.
R13	Rendah	`app/Livewire/Payrolls/Show.php:701-707, 810-815`	**Tanggal pembayaran payroll menerima tanggal masa depan.** Rule paymentDate dan itemPaymentDate hanya required|date. Alur kasbon sudah memakai before_or_equal:today. **Rekomendasi:** Tambahkan before_or_equal:today pada kedua rule.
R14	Rendah	`app/Livewire/Payrolls/ManageItem.php:2741`	**Fallback audit ke User::first().** $user = auth()->user() ?? $this->period->creator ?? User::first() - jika user tidak terdeteksi, perubahan payroll diatribusikan ke user arbitrer (biasanya ID 1). **Rekomendasi:** Gagalkan penyimpanan (return false/abort) bila tidak ada user terautentikasi.
R15	Rendah	`app/Livewire/Overtimes/Index.php:701-728`	**Modal lembur legacy membuat kehadiran 6 hari untuk semua karyawan.** openAttendanceModal() auto-buat baris OvertimePeriodAttendance attended_days => 6 dan total_meal_allowance = 6 x tarif untuk semua karyawan aktif, termasuk yang tidak berlembur/tidak hadir. Komponen baru PeriodAttendance sengaja melewati karyawan tanpa kehadiran. **Rekomendasi:** Port logika skip/derivasi PeriodAttendance ke modal lama, atau hapus jalur legacy.
R16	Rendah	`resources/views/livewire/payrolls/show.blade.php:796`	**Colspan empty-state tidak sinkron dengan kolom header.** Colspan 11 hanya untuk direktur, tetapi kolom checkbox hanya muncul saat direktur DAN status submitted. Kondisi pada header dan empty-state memakai ekspresi berbeda. **Rekomendasi:** Samakan kondisi dengan header: hasRole(direktur) && status === submitted ? 11 : 10.
R17	Rendah	`resources/views/livewire/overtimes/index.blade.php:346, 349, 1026, 1029; pending-admin-modal.blade.php:89; pending-director-modal.blade.php:84, 93`	**Interpolasi string JS pada onclick untuk reference_number.** onclick="confirmApproveOvertime({{ $sub->id }}, '{{ $sub->reference_number }}')" - escaping HTML Blade tidak membuat nilai aman untuk literal string JS dalam kutip tunggal. **Rekomendasi:** Simpan nilai pada atribut data-reference dan baca dari handler (pola openPayrollApprovalMenu).
R18	Rendah	`resources/views/livewire/cash-advances/index.blade.php:1044-1098`	**Init Select2 pada elemen yang tidak ada (main_employee_selector).** Kode JS menginisialisasi Select2 dan sinkronisasi filter untuk #main_employee_selector, tetapi tidak ada elemen dengan id tersebut di seluruh views. **Rekomendasi:** Hapus blok mati tersebut atau arahkan ke id selector filter recap yang sebenarnya.
R19	Rendah	`resources/views/layouts/app.blade.php:211, 232, 239`	**Bridge SweetAlert global berfallback ke delete-post.** const action = data.action || 'delete-post' dan default modal 'postModal' untuk event global. **Rekomendasi:** Default action ke null dan no-op/log bila kosong.
R20	Rendah	`resources/views/layouts/guest.blade.php:17; package.json:10`	**Halaman auth bergantung pada symlink public/node_modules.** bootstrap-social.css dimuat dari /node_modules/... pada public, dibuat oleh postinstall npm yang dibungkus try/catch. **Rekomendasi:** Impor bootstrap-social.css ke build Vite/Tailwind atau salin ke public/assets/css.
R21	Info	`resources/js/app.js; welcome.blade.php:14`	**resources/js/app.js kosong - bundle Vite bukan jalur utama aplikasi.** app.js hanya berisi komentar, sementara UI utama berjalan di atas aset precompiled public/assets. **Rekomendasi:** Dokumentasikan arsitektur aset atau mulai migrasi bertahap ke Vite.

Tabel 4. Rincian 20 temuan rendah dan 1 temuan info.

6. Area yang Terverifikasi Bersih

Sebagai keseimbangan laporan, area berikut telah diperiksa dan dinyatakan tidak ditemukan masalah:

- Perhitungan pajak (PPh 21): bracket Pasal 17, jumlah PTKP dan kategori TER, batas biaya jabatan, batas JP/KES, penanganan non-NPWP +20 persen, dan konvergensi gross-up semuanya konsisten secara aritmetika; guard has_unpaid_period mencegah rekonsiliasi pada periode yang belum dibayar.

- Alur approval dan pembayaran kasbon secara konsisten memakai transaksi database dan lockForUpdate; reservasi nomor urut (insertOrIgnore + lockForUpdate) aman dari race.

- Kebijakan (Policy) dan komponen kasbon, karyawan, lembur, serta SecureDocumentController secara konsisten membatasi pengguna berperan karyawan pada datanya sendiri; endpoint print slip memeriksa ulang peran dan status approval.

- Seluruh wire:click, $wire.set/call, dan Livewire.dispatch pada Blade cocok dengan method komponennya, termasuk seluruh listener #[On(...)]; tidak ada form tanpa CSRF (semua form adalah wire:submit milik Livewire).

- Validasi unggahan berkas lainnya benar (earlyProofDocument, itemPaymentProof, foto/CV karyawan dengan mimes dan max size).

- Print views (payrolls/print, print-batch, print-yearly-summary, overtimes/print-weekly) lengkap variabelnya; terbilang_id terdefinisi; print CSS menyembunyikan action bar dan memaksa page break dengan benar.

- Blok Alpine/x-data menginisialisasi seluruh state yang direferensikan; chart guard terhadap Chart yang belum termuat; escaping pada titik JS rawan (approval menu, link WhatsApp) ditangani dengan benar.

- Cascade deletePeriod aman (foreign key cascadeOnDelete terverifikasi pada migrasi).

7. Rekomendasi Urutan Perbaikan

1. **Tahap 1 - Kritis (keamanan).** H2 (pindahkan bukti pembayaran ke disk local + route terotorisasi), H3 (gate check dan jadikan cleanup aksi eksplisit), H1 (unique index year+month dan tangani constraint violation).

2. **Tahap 2 - Sedang (integritas payroll dan kasbon).** H8 dan H9 (sinkronisasi potongan payslip dengan saldo kasbon), H12 (epsilon lunas yang konsisten), H10 (validasi tanggal periode), H7 (validasi tanggal import absensi), H4 (hapus fallback ID numerik).

3. **Tahap 3 - Sedang (validasi input dan otorisasi).** H5 (validasi type komponen gaji), H6 (kebijakan password), H11 (overlap lembur lintas hari), H13 (validasi field payout mingguan), H14 (scope payroll item per periode), H15 (lempar ulang AuthorizationException), H16 (escaping output Blade).

4. **Tahap 4 - Rendah.** R1-R20 sesuai kapasitas; yang paling berdampak: R15 (tunjangan fiktif modal legacy), R8 (standarisasi epsilon), R13 (tanggal bayar masa depan), R4 (gaji masa depan terangkat).

5. **Tahap 5 - Kebersihan.** R19, R18, R17, R16, R21 dan pemeliharaan berkala (uji lintas driver database, audit lintas peran setiap menambah komponen baru).

Dokumen ini dihasilkan dari audit statis kode pada tanggal 31 Oktober 2026. Seluruh temuan telah diverifikasi terhadap kode sumber pada lokasi yang tercantum. Eksekusi perbaikan menunggu persetujuan.